



QUANT LAB USA INC

Technical Due Diligence Checklist for SMB Acquirers

A 50-item TDD checklist plus interview script for acquirers, search funds, and investors evaluating SMB tech-enabled businesses. Surface code, security, infrastructure, and team risk on a structured rubric in one focused week, before you sign the LOI.

Published 2026 - Free founder and operator resource
quantlabusa.dev/resources

Table of Contents

- Section 1 - Business and Technology Overview
- Section 2 - Codebase Health
- Section 3 - Infrastructure and Operations
- Section 4 - Security Posture
- Section 5 - Compliance and Data
- Section 6 - Team and Key-Person Risk
- Section 7 - Vendor and Third-Party Risk
- Section 8 - Customer and Integration Risk
- Section 9 - Interview Script and Risk-Flag Rubric

About this document

This document is a free resource published by QUANT LAB USA INC, a Georgia-incorporated technology company building custom business software, SaaS platforms, and security engineering for mid-market and SMB operators. It is informational only and does not constitute legal, tax, accounting, or financial advice. Always verify decisions with a qualified licensed professional in your jurisdiction.

Section 1

Business and Technology Overview

The first six items in the checklist are foundational. They give you the context to interpret every subsequent finding. Run these on the data-room materials before the engineering interview.

Item 1: Core Product Surface

Document the primary products, customer-facing surfaces, and the revenue split by product line. A target with three products but 90% revenue from one product has a different risk profile than a target with three products at one-third each.

Item 2: Technology Stack

Languages, frameworks, primary databases, hosting providers, key SaaS dependencies. Watch for legacy frameworks (PHP 5, Python 2, jQuery-heavy frontend with no build system) - rewrite risk is real and expensive.

Item 3: Hosting Footprint

Cloud accounts, regions, ownership of the root account, billing visibility. A surprisingly common finding: production runs on the founder's personal AWS account.

Item 4: Five Most-Used Screens

Ask for the five most-trafficked URLs in the application. This is a fast signal of where customer value (and code complexity) is actually concentrated.

Item 5: Five Most-Changed Files

Run a git log analysis on the five most-modified files in the last six months. These are the files that any post-close engineering team will be touching. If they are inscrutable, that is a flag.

Item 6: Active Customer-Facing Issues

Review the open support tickets, the public status page, and any customer-communication channel for known active issues. A target with 12 open critical customer issues has a different risk profile than one with 2.

Section 2

Codebase Health

Code quality is the most-reviewed and least-correctly-assessed dimension of TDD. The checklist items below produce a defensible signal in a short window.

Item 7: Repository Structure

Single repo or microservices? Number of services? Build and deploy infrastructure shared or duplicated? Excessive service fragmentation at SMB scale is often a flag - 25 microservices for an 8-person engineering team is a post-close consolidation project.

Item 8: Test Coverage

What is the test coverage of the production codebase? Are critical paths covered by integration or end-to-end tests? Less than 30% coverage on a codebase older than 3 years is a meaningful risk.

Item 9: CI/CD Posture

Does the team deploy on commit, on PR merge, or via manual deploy? How long does CI take? What is the deploy rollback procedure? Manual-deploy environments have a higher post-close stabilization cost.

Item 10: 90-Day Commit Cadence

How many commits in the last 90 days? How distributed across contributors? A codebase with 90% of commits from one contributor has key-person risk that may materialize at close if that contributor leaves.

Item 11: Contributor Concentration

List all contributors to the codebase in the last 12 months. Note any contractor or ex-employee with significant commit history; their post-close access or knowledge transfer is a planning item.

Item 12: Documented Architectural Decisions

Are there ADRs (Architecture Decision Records) or equivalent? Even informal documentation of why key architectural choices were made? Undocumented architecture compounds risk in post-close evolution.

Item 13: Open Tech Debt

Ask the engineering lead for their top-three tech debt items. If they cannot name three, they have not been paying attention. If they have a written backlog, review it.

Item 14: Dependency Health

Run a quick dependency analysis: how many dependencies are end-of-life or unmaintained? How many have known critical vulnerabilities? Stale dependencies are remediation cost.

Section 3

Infrastructure and Operations

Operational maturity correlates strongly with post-close ease of integration. These seven items surface where the operational risk concentrates.

Item 15: Hosting Account Ownership

Is the production cloud account owned by the company, or by a founder, contractor, or MSP? Account ownership transfer is a closing condition.

Item 16: Infrastructure as Code

Is production infrastructure described in IaC (Terraform, Pulumi, CloudFormation)? Or is it click-ops? Click-ops production is recoverable but post-close standardization cost is real.

Item 17: Secrets Management

How are production secrets stored? Centralized vault (HashiCorp Vault, AWS Secrets Manager, 1Password), environment variables in CI, or pasted into chat at some point? The last pattern is a security finding.

Item 18: Backup and Disaster Recovery

How often does production data back up? Are backups immutable? When was the last documented restore test? RTO and RPO targets - documented or not?

Item 19: Monitoring and Alerting

What's monitored, where do alerts go, and who responds? An on-call rotation or a single-person Slack ping is meaningful difference for post-close staffing.

Item 20: On-Call Structure

Documented on-call rotation? Pager tool in place? Post-incident retrospective discipline? A founder-only on-call rotation is a closing-condition item.

Item 21: Retrospective Practice

Are post-incident retrospectives written and stored? A team that does retrospectives produces a more recoverable post-close engineering culture.

Section 4

Security Posture

Security findings are the most common reason a TDD escalates beyond a checklist review. These eight items surface the most common SMB security gaps.

Item 22: Vulnerability Surface

Run an external vulnerability scan against the target's primary internet-facing properties. Critical or high-severity findings are a closing-condition item.

Item 23: Dependency Hygiene

Are dependencies scanned in CI? Are critical vulnerabilities patched within 30 days? An unpatched 18-month-old critical CVE is a flag.

Item 24: Secrets Exposure

Has the target's GitHub history been scanned for accidentally-committed secrets? Have those secrets been rotated? This is one of the most common findings.

Item 25: Authentication Patterns

MFA enforced on all SaaS accounts? Phishing-resistant MFA on privileged accounts? Shared accounts or weak password policies?

Item 26: RBAC and Access Control

Are production access permissions reviewed quarterly? Are ex-employees offboarded from all systems? How long does deprovisioning typically take?

Item 27: Audit Logging

What user actions are logged? How long are logs retained? Are logs centralized and queryable, or scattered across systems?

Item 28: Recent Security Incidents

Ask explicitly: any security incidents, data breaches, or near-misses in the last 24 months? Get a written response. Disclosure here is a material risk topic.

Item 29: SOC 2 Status

SOC 2 Type II in place? Type I? In progress? None? Other compliance attestations (ISO 27001, HITRUST, FedRAMP, etc.)?

Section 5

Compliance and Data

If the target operates in a regulated category, compliance gaps can be material. These six items surface the most common compliance findings.

Item 30: Regulatory Regimes

Which regulatory regimes apply to the target? HIPAA, PCI-DSS, GDPR, CCPA, GLBA, FERPA, others? Has the target completed any required attestations?

Item 31: Customer-Data Inventory

What categories of customer data are stored? PII, payment data, health data, financial data? Is there a documented data inventory or data map?

Item 32: Data Residency

Where is customer data stored - region and country? Are there contractual data-residency obligations the target must meet?

Item 33: Data Retention Policy

Is there a written data retention and deletion policy? Is it followed? Many targets retain customer data indefinitely - this is regulatory exposure under GDPR and CCPA.

Item 34: Privacy Policy and Terms

Are the public privacy policy and terms of service current? Do they accurately reflect actual data practices?

Item 35: Audit History

Has the target been audited recently for any compliance regime? What did the audit produce? Are remediation items resolved?

Section 6

Team and Key-Person Risk

Engineering team risk is the most common reason a TDD recommends against close or recommends a holdback. These six items surface team-side risk.

Item 36: Engineering Headcount

Full-time engineering headcount, contractor headcount, contractor-to-employee ratio. A team with three FTEs and seven contractors has different post-close risk than a 10-FTE team.

Item 37: Bus Factor

Identify the bus factor - how many engineers know critical production systems well enough to operate them solo? Single-engineer bus factor on key systems is a closing-condition item.

Item 38: Documented Onboarding

Is there an onboarding document or runbook for new engineers? How long does current onboarding typically take? Post-close, you may be onboarding new team members against this documentation.

Item 39: Retention Plan

What is the retention plan for key engineers post-close? Are there retention bonuses, equity rollovers, or other commercial incentives? Key-engineer departure in the first 90 days post-close is one of the most common TDD findings to materialize.

Item 40: Contractor Risk

What are the terms of contractor engagements? Are contracts assignable to the acquirer? Are critical systems being operated by contractors who may not transition?

Item 41: Internal Documentation

Is there an internal wiki, runbook collection, or operational documentation set? Is it current?

Section 7

Vendor and Third-Party Risk

The target's third-party dependencies become your third-party dependencies post-close. These five items surface the highest-risk vendor relationships.

Item 42: Critical SaaS Dependencies

List the top 10 SaaS vendors the target depends on. For each: contract term, renewal date, alternatives if the vendor disappeared, total annual spend.

Item 43: Contractor and Supplier List

Active contractors and key suppliers. For each: relationship length, deliverable, contract assignability.

Item 44: Data Processing Agreements

Are DPAs in place with all third parties processing customer data? Are they current with regulatory requirements?

Item 45: Third-Party SLAs

Which third parties have SLAs that affect product reliability? What is the history of SLA breaches?

Item 46: Concentration Risk

Any single vendor representing more than 20% of vendor spend or more than 30% of product critical path? Concentration risk that does not appear in a vendor list often surfaces post-close as a renewal-negotiation issue.

Section 8

Customer and Integration Risk

The customer-facing surface inherits to the acquirer. These four items surface customer-side and integration-side risk.

Item 47: Customer-Facing Integrations

What integrations does the product expose to customers? What SLAs are committed on those integrations? What is the integration support burden?

Item 48: Top-Customer Custom Code

Are there top customers running on custom code or non-standard configurations? How much engineering time is consumed maintaining customer-specific code paths?

Item 49: Open Feature Request Queue

Review the open feature request queue. Are there commitments to customers that haven't been delivered? Are there acquisition-conditional features in the queue?

Item 50: Customer SLAs

What customer-facing SLAs is the platform under? Uptime, response time, incident response. Are they met today?

Section 9

Interview Script and Risk-Flag Rubric

Use the 60-minute interview script below for the conversation with the seller's engineering lead. Customize for the target but stay disciplined on time.

60-Minute Interview Script

- Minutes 0-5: Introductions and background of the engineering lead.
- Minutes 5-15: Walk through the architecture from a customer request to database write. Listen for which parts the engineer answers confidently and which they hedge on.
- Minutes 15-25: Codebase health. Test coverage, deploy cadence, contributor concentration, tech-debt backlog.
- Minutes 25-35: Operational maturity. Backup posture, monitoring, on-call, incident history.
- Minutes 35-45: Security. Authentication, dependency hygiene, secrets, incident disclosure.
- Minutes 45-55: Team and retention. Bus factor, contractor exposure, retention plan.
- Minutes 55-60: Open question: 'What would you want a thoughtful acquirer to know about this engineering organization that hasn't come up?' This question frequently produces the single most important data point in the interview.

Risk-Flag Rubric

Severity	Definition	Typical Action
Red	Findings that should kill the deal or trigger material price adjustment.	Reprioritize, holdback, or pass.
Yellow	Findings that require remediation but are recoverable post-close.	Document remediation plan; price the cost into the deal.
Green	Acceptable findings consistent with the target size and stage.	Note but no action required.

Sample Findings by Severity

- **Red:** Production cloud account on founder's personal credentials with no backups; recent undisclosed security incident; single-contributor codebase where contributor is exiting at close.
- **Yellow:** 25% test coverage on a 4-year-old codebase; stale dependencies with known CVEs; informal on-call with no rotation.

- **Green:** Click-ops infrastructure at small scale; thin internal documentation; modest tech-debt backlog with clear remediation path.

IC-Memo Summary Template

Sample IC-memo paragraph: '[TARGET] technology assessment surfaces [N] red flags, [N] yellow flags, and [N] green findings. Material red items: [ITEMS]. Yellow items collectively require approximately [X] weeks of post-close engineering remediation, estimated at \$[Y]. Recommendation: [PROCEED / HOLDBACK / REPRICE / PASS].'

Contact & Next Steps

Ready to act on what is in this document?

If the contents of this PDF prompted a question you want a second set of eyes on, or if you are ready to scope a related engagement, we run a 20-minute discovery call at no cost. The conversation is structured: 5 minutes on your context, 10 minutes on the specific decision in front of you, 5 minutes on what good next steps look like.

- Book a 20-minute scoping call: quantlabusa.dev/contact
- Learn about our Custom Business Software practice: quantlabusa.dev/services/custom-business-software
- Browse our full resources library: quantlabusa.dev/resources
- Read recent case studies: quantlabusa.dev/work
- Pricing and discovery sprint options: quantlabusa.dev/pricing

Who is QUANT LAB USA?

QUANT LAB USA INC is a Georgia-incorporated technology consultancy. We build custom business software, SaaS platforms, payments and licensing infrastructure, and security engineering for mid-market and SMB operators. We are deliberately structured as a small, senior-engineering-led practice - the people on your scoping call are the people who build the system. If a custom build is on the table, we typically begin with a paid discovery sprint that produces wireframes, a database schema, and a phased build estimate.

QUANT LAB USA INC

Georgia C-Corporation - SOS #26086454 - EIN 42-2039870

Web: quantlabusa.dev - Email: hello@quantlabusa.dev

Resources library: quantlabusa.dev/resources